UNIVERSIDAD MADERO (UMAD)

Licenciatura en Informática y Seguridad en Redes.

Análisis Integral de un Delito Cibernético

Materia: DELITOS CIBERNÉTICOS

Presenta: Christian Ayala Enríquez

Fecha de entrega: 6 de Septiembre de 2026

Actividad de Aprendizaje 1

Análisis Integral de un Delito Cibernético

Informe técnico-forense de investigación de ciberdelito

Asignatura: Delitos Cibernéticos
Caso seleccionado: Caso 1. Fraude Financiero y Ataque al SPEI (México, 2018)
Modalidad: Investigación y análisis de caso

---

1. Introducción

La transformación digital del sistema financiero mexicano ha permitido que una gran cantidad de operaciones bancarias se realicen de manera electrónica. Uno de los componentes fundamentales de esta infraestructura es el Sistema de Pagos Electrónicos Interbancarios (SPEI), operado por el Banco de México, mediante el cual las instituciones participantes pueden realizar transferencias electrónicas de fondos.

Durante abril y mayo de 2018 se registró uno de los incidentes de ciberseguridad más relevantes para el sistema financiero mexicano. Diversas instituciones participantes del SPEI fueron víctimas de ataques dirigidos contra los aplicativos utilizados para preparar órdenes de pago y conectarse con el sistema de pagos. Banco de México informó que entre la segunda mitad de abril y la primera mitad de mayo cinco participantes experimentaron ataques.

Un aspecto fundamental para comprender el incidente es que **el SPEI central no fue vulnerado**. De acuerdo con Banco de México, los atacantes comprometieron infraestructura tecnológica perteneciente a los participantes y manipularon componentes relacionados con las aplicaciones utilizadas para generar y enviar órdenes de pago.

El ataque permitió introducir transacciones ilegítimas y ocasionó pérdidas económicas estimadas en aproximadamente **300 millones de pesos**. Documentación de Banco de México señala que el código malicioso permitió alterar aplicaciones relacionadas con la conexión al SPEI y distribuir recursos desde cuentas concentradoras hacia cuentas específicas utilizadas posteriormente para retirar el dinero.

El presente informe analiza el incidente desde una perspectiva técnica, forense y jurídica, identificando la naturaleza del ciberdelito, los posibles vectores de ataque, los activos comprometidos, la evidencia digital que permitiría sustentar una investigación y las autoridades mexicanas que podrían intervenir.

---

2. Narración del caso

2.1 ¿Qué ocurrió?

Entre abril y mayo de 2018 diferentes instituciones financieras mexicanas sufrieron ataques cibernéticos dirigidos a los sistemas utilizados para preparar y enviar órdenes de pago al SPEI.

Banco de México registró el primer evento el **17 de abril de 2018** y posteriormente identificó otros cuatro eventos: dos ocurridos el 24 de abril, uno el 26 de abril y otro el 8 de mayo. Los ataques se enfocaron en diversos componentes de las aplicaciones utilizadas por los participantes para conectarse al SPEI, así como en la infraestructura informática y de telecomunicaciones donde dichas aplicaciones estaban instaladas.

Un elemento importante es que los aplicativos de conexión no eran proporcionados directamente por Banco de México. Cada participante era responsable de contar con ellos, ya fueran desarrollados internamente o proporcionados por terceros. Banco de México señaló que, en los casos identificados, los aplicativos de conexión habían sido desarrollados por terceros.

El ataque permitió que los delincuentes introdujeran transferencias no autorizadas durante alguna etapa del procesamiento de las órdenes de pago.

2.2 Víctimas

Las víctimas directas fueron principalmente las instituciones financieras participantes del SPEI cuya infraestructura fue comprometida.

De manera indirecta también fueron afectados:

- Clientes de las instituciones financieras.
- Instituciones receptoras.
- El sistema financiero mexicano.
- Proveedores tecnológicos relacionados con las instituciones afectadas.
- El propio sistema de confianza en los medios de pago electrónicos.

Banco de México señaló que los recursos de los clientes de las instituciones financieras se encontraban seguros y que el sistema central del SPEI no había sido comprometido.

2.3 Impacto económico

El impacto económico fue considerable. Una estimación oficial posteriormente documentada situó el daño para los participantes del SPEI en aproximadamente **300 millones de pesos**.

Además del dinero directamente sustraído, el incidente generó costos asociados con:

- Investigación forense.
- Recuperación de sistemas.
- Contención de incidentes.
- Implementación de controles adicionales.
- Reforzamiento de infraestructura.
- Investigación de cuentas receptoras.
- Monitoreo de transacciones.
- Reputación y confianza del sistema financiero.

2.4 Impacto operativo

Como respuesta a los incidentes, Banco de México implementó diversas medidas de contingencia. Entre ellas estuvo la migración de participantes afectados o considerados de mayor riesgo hacia una plataforma de operación contingente, así como la implementación de alertas y controles adicionales para detectar anomalías en los mensajes de pago.

---

3. Taxonomía del delito

El incidente puede clasificarse de la siguiente manera:

Categoría	Clasificación
Tipo de ciberdelito	Fraude financiero / acceso ilícito a sistemas informáticos / manipulación informática
Objetivo del atacante	Obtener beneficio económico
Objetivo secundario	Manipular procesos financieros y evadir controles
Técnica principal	Compromiso de infraestructura y manipulación de aplicaciones
Activos comprometidos	Aplicativos de conexión al SPEI, infraestructura tecnológica y sistemas bancarios
Información afectada	Información y órdenes de pago
Disponibilidad	Afectación operativa y establecimiento de mecanismos de contingencia
Integridad	Principalmente comprometida
Confidencialidad	Posiblemente comprometida durante el acceso, aunque el objetivo principal fue económico
Impacto financiero	Aproximadamente 300 millones de pesos

Impacto institucional	Alto
Complejidad	Alta

Desde el modelo de seguridad **CIA (Confidentiality, Integrity and Availability)**, el atributo más directamente afectado fue la **integridad**.

Los atacantes no necesitaban necesariamente destruir la infraestructura. Su objetivo consistió en modificar el comportamiento de componentes utilizados para procesar órdenes de pago, provocando que operaciones fraudulentas fueran introducidas dentro de un flujo que normalmente debía contener únicamente transacciones legítimas.

---

4. Técnicas de hackeo utilizadas

4.1 Compromiso de infraestructura

Banco de México indicó que los atacantes vulneraron infraestructura tecnológica perteneciente a los participantes y posteriormente insertaron transacciones ilegítimas en alguna etapa del proceso realizado por los aplicativos de conexión al SPEI.

Esto significa que el ataque no necesitó vulnerar directamente el núcleo del SPEI.

El modelo de ataque puede representarse de forma simplificada como:

Atacante → infraestructura bancaria → aplicación de conexión → modificación del proceso → orden de pago ilegítima → SPEI → cuenta receptora

4.2 Manipulación de aplicaciones

Una de las características más relevantes fue la manipulación de aplicaciones relacionadas con la conexión al SPEI.

La documentación oficial posteriormente describió el incidente como una alteración de los aplicativos mediante código malicioso, capaz de distribuir recursos desde cuentas concentradoras hacia cuentas específicas utilizadas para extraer el dinero.

Desde una perspectiva de seguridad, este mecanismo puede considerarse un ataque dirigido contra la **integridad del proceso transaccional**.

4.3 Abuso de cuentas receptoras

El modus operandi documentado incluía transferencias hacia cuentas reales que podían funcionar como mecanismos intermedios para retirar los recursos.

Estas cuentas pueden conceptualizarse como cuentas "mula", es decir, cuentas utilizadas para recibir fondos obtenidos ilícitamente y posteriormente permitir su extracción o dispersión.

Esto introduce una segunda fase del ataque: después del compromiso tecnológico se requiere una infraestructura financiera para convertir el acceso informático en beneficio económico.

4.4 Código malicioso

La existencia de código malicioso es relevante desde el punto de vista forense. Sin embargo, debe evitarse afirmar un nombre específico de malware si la evidencia pública disponible no lo identifica.

Por ello, en una investigación formal deberían buscarse:

- Ejecutables desconocidos.
- DLL modificadas.
- Scripts.
- Tareas programadas.
- Servicios creados recientemente.
- Cambios en archivos de aplicaciones.
- Procesos anómalos.
- Conexiones de red sospechosas.
- Modificaciones del registro.
- Archivos temporales.
- Logs de autenticación.
- Indicadores de compromiso.

---

5. Vector de ataque

El vector de ataque puede reconstruirse utilizando la información pública disponible y diferenciando claramente los hechos documentados de las hipótesis que deberían comprobarse mediante análisis forense.

5.1 Acceso inicial

El primer paso habría consistido en obtener acceso no autorizado a la infraestructura tecnológica de una institución participante.

La información oficial confirma que los atacantes vulneraron infraestructura de los participantes, pero la información pública disponible no permite establecer con certeza un único mecanismo de acceso inicial para todos los incidentes.

Por lo tanto, las hipótesis forenses deberían incluir:

- Explotación de vulnerabilidades.
- Credenciales comprometidas.
- Compromiso de proveedores.
- Malware.
- Acceso remoto no autorizado.
- Ingeniería social.
- Explotación de sistemas expuestos.

No sería técnicamente correcto afirmar que todos los bancos fueron comprometidos mediante phishing, por ejemplo, porque esa conclusión no está sustentada por la información oficial disponible.

5.2 Escalada de privilegios

Una vez obtenido el acceso inicial, el atacante habría necesitado permisos suficientes para modificar componentes relevantes de la infraestructura.

Una investigación debería determinar:

- Cuenta utilizada.
- Privilegios de la cuenta.
- Servidor comprometido.
- Procesos ejecutados.
- Cambios realizados.
- Credenciales utilizadas.
- Eventos de autenticación.
- Modificaciones de grupos administrativos.

La escalada de privilegios sería especialmente relevante si el atacante logró modificar aplicaciones o servicios ejecutados con privilegios elevados.

5.3 Movimiento lateral

Debido a que el ataque involucró infraestructura tecnológica asociada con procesos financieros, una hipótesis razonable de investigación es que el atacante pudo desplazarse desde un equipo inicialmente comprometido hacia otros sistemas relevantes.

La investigación debería analizar:

- Conexiones SMB.
- RDP.
- SSH.
- WMI.
- PowerShell.
- Active Directory.
- Autenticaciones entre servidores.

- Credenciales reutilizadas.
- Accesos administrativos.
- Tráfico interno.

Sin embargo, nuevamente debe distinguirse entre **lo que una investigación debería buscar** y lo que públicamente se confirmó.

5.4 Persistencia

Para mantener acceso a la infraestructura, los investigadores deberían buscar mecanismos como:

- Cuentas creadas recientemente.
- Servicios persistentes.
- Tareas programadas.
- Claves de registro.
- Backdoors.
- Web shells.
- Scripts automatizados.
- Malware residente.
- Llaves SSH desconocidas.
- Cambios en mecanismos de autenticación.

La presencia de estos artefactos permitiría determinar si el atacante mantuvo acceso durante un periodo prolongado.

5.5 Manipulación de transacciones

Esta fue la fase crítica.

Los atacantes lograron insertar transacciones ilegítimas durante alguna etapa del procesamiento utilizado por los aplicativos de conexión al SPEI. Banco de México señaló que las operaciones ilegítimas incluían una cuenta emisora inexistente y una cuenta receptora real.

Esto indica que el atacante no necesariamente necesitaba modificar directamente el SPEI central.

En términos conceptuales:

1. Se compromete la infraestructura del participante.
2. Se altera el proceso de generación o procesamiento de órdenes.
3. Se genera una operación fraudulenta.
4. La operación es enviada al sistema de pagos.
5. El dinero llega a una cuenta receptora.
6. Los recursos son retirados o dispersados.

5.6 Exfiltración o extracción financiera

En este caso, el término exfiltración debe utilizarse con cuidado.

No se trató principalmente de una exfiltración tradicional de archivos, sino de una **extracción ilícita de recursos financieros mediante transacciones electrónicas manipuladas**.

Por ello, la evidencia financiera es tan importante como la evidencia informática.

5.7 Impacto final

El impacto final consistió en pérdidas económicas, interrupciones operativas y la necesidad de implementar mecanismos de contingencia y controles adicionales.

Banco de México estableció medidas para detectar anomalías en los mensajes de pago y reforzar los controles utilizados por los participantes.

---

6. Hallazgos forenses

Una investigación informática forense debe buscar evidencia que permita relacionar:

actor → sistema comprometido → acción realizada → transacción fraudulenta → cuenta receptora → beneficio económico.

6.1 Logs

Los registros de eventos serían una de las principales fuentes de evidencia.

Se deberían obtener:

- Logs de servidores.
- Logs de firewalls.
- Logs de VPN.
- Logs de Active Directory.
- Logs de autenticación.
- Logs de aplicaciones.
- Logs de bases de datos.
- Logs de sistemas operativos.
- Logs de servicios financieros.
- Registros del aplicativo de conexión al SPEI.

Los investigadores deberían establecer una línea temporal correlacionando todos estos registros.

6.2 Direcciones IP

Las direcciones IP podrían utilizarse para determinar:

- Origen de conexiones.
- Accesos remotos.
- Comunicación con servidores externos.
- Actividad administrativa.
- Infraestructura utilizada durante el ataque.

Sin embargo, una dirección IP por sí sola no identifica necesariamente al atacante.

Debe correlacionarse con:

- Proveedor de Internet.
- Horarios.
- Logs de autenticación.
- Dispositivo utilizado.
- Cuenta comprometida.
- Información de VPN.
- Registros de proveedores.

6.3 Hashes

Durante la adquisición forense deberían calcularse hashes criptográficos de imágenes y archivos relevantes.

Por ejemplo:

- SHA-256.
- SHA-512.
- MD5 como referencia histórica, aunque no como mecanismo criptográfico moderno principal.

Los hashes permitirían demostrar que una evidencia analizada posteriormente corresponde a la evidencia originalmente adquirida.

6.4 Malware

Si se localiza código malicioso, debería realizarse:

- Análisis estático.
- Análisis dinámico.
- Extracción de indicadores de compromiso.
- Identificación de dominios.
- Identificación de IP.
- Análisis de cadenas.

- Análisis de comportamiento.
- Comparación de hashes.

No debe atribuirse un malware específico sin evidencia técnica que lo confirme.

6.5 Artefactos digitales

Los investigadores deberían analizar:

- Prefetch.
- Event Logs.
- Windows Registry.
- PowerShell logs.
- Scheduled Tasks.
- Servicios.
- Archivos temporales.
- Navegadores.
- Memoria RAM.
- Procesos activos.
- Historial de comandos.
- Archivos recientemente modificados.
- Bases de datos.
- Logs de aplicaciones.

6.6 Evidencia financiera

La evidencia financiera es especialmente importante en este caso.

Se deberían correlacionar:

- Cuenta emisora.
- Cuenta receptora.
- Hora de operación.
- Monto.
- Institución de origen.
- Institución receptora.
- Folio de operación.
- Cuenta concentradora.
- Registros de retiro.
- Cajeros utilizados.
- Transferencias posteriores.

Esta información permitiría construir una cadena financiera del delito.

---

7. Cadena de custodia de la evidencia digital

La evidencia digital debe ser recolectada siguiendo procedimientos que permitan preservar su integridad.

El Código Nacional de Procedimientos Penales establece en su artículo 227 que la cadena de custodia es el sistema de control y registro aplicado al indicio, evidencia, objeto, instrumento o producto del hecho delictivo desde su localización hasta que la autoridad competente determine su conclusión. También exige registrar aspectos como identidad, estado original, condiciones de recolección, preservación, traslado y las personas que tuvieron contacto con la evidencia.

En el caso analizado, una correcta cadena de custodia debería incluir:

1. Identificación del servidor o dispositivo.
2. Registro de fecha y hora.
3. Identificación del perito.
4. Aislamiento del dispositivo.
5. Adquisición forense.
6. Generación de imagen bit a bit cuando corresponda.
7. Cálculo de hash.
8. Documentación de herramientas utilizadas.
9. Preservación del original.
10. Análisis sobre una copia forense.
11. Registro de cada transferencia de evidencia.

Esto resulta fundamental porque una evidencia digital puede ser fácilmente modificada si no se aplican controles adecuados.

---

8. Fundamentación jurídica aplicable en México

8.1 Código Penal Federal

El Código Penal Federal contempla disposiciones específicas relacionadas con el acceso ilícito a sistemas y equipos de informática.

Particularmente relevantes para este caso son los artículos **211 Bis y subsecuentes**, que integran el capítulo relacionado con revelación de secretos y acceso ilícito a sistemas y equipos de informática.

El artículo 211 Bis 4 contempla específicamente conductas relacionadas con sistemas y equipos de informática de instituciones que integran el sistema financiero. Históricamente, la disposición sanciona la modificación, destrucción o pérdida de información realizada sin autorización, así como el conocimiento o copia no autorizados de información protegida.

El artículo 211 Bis 5 contempla también la conducta de quien, teniendo autorización para acceder a sistemas de instituciones del sistema financiero, los modifica, destruye o provoca pérdida de información de manera indebida; asimismo contempla el supuesto de copia indebida. Las penas pueden incrementarse cuando intervienen funcionarios o empleados de instituciones financieras.

En el caso SPEI, estos artículos resultan relevantes porque la conducta investigada implicó la manipulación no autorizada de sistemas relacionados con instituciones financieras.

8.2 Fraude y otras conductas delictivas

Además de los delitos informáticos propiamente dichos, la investigación puede considerar otras figuras penales dependiendo de los hechos concretamente acreditados.

El uso de sistemas informáticos puede constituir el medio mediante el cual se materializa un delito patrimonial.

Por ello, el análisis jurídico no debe limitarse exclusivamente a decir "fue un hackeo". Debe determinar:

- Qué sistema fue comprometido.
- Qué conducta realizó el atacante.
- Qué daño produjo.
- Quién obtuvo el beneficio.
- Cómo se realizó la transferencia.
- Si existió organización entre diferentes participantes.
- Si existieron actos posteriores para ocultar o disponer de los recursos.

8.3 Protección de datos personales

La legislación mexicana en materia de protección de datos personales también puede resultar relevante cuando durante un incidente de seguridad se comprometen datos personales.

Debe hacerse una precisión temporal importante: la **Ley Federal de Protección de Datos Personales en Posesión de los Particulares de 2010 fue abrogada el 20 de marzo de 2025 y sustituida por una nueva legislación federal en la materia**.

Para analizar jurídicamente un hecho ocurrido en 2018 debe considerarse la legislación vigente en ese momento, mientras que para explicar el marco actual puede citarse la legislación vigente.

La legislación de protección de datos exige medidas orientadas a proteger los datos personales frente a daño, pérdida, alteración, destrucción o acceso y tratamiento no autorizado.

En este caso, su aplicación dependería de determinar si durante el incidente fueron comprometidos datos personales y qué institución tenía la calidad de responsable del tratamiento.

8.4 Código Nacional de Procedimientos Penales

El Código Nacional de Procedimientos Penales proporciona el marco procesal para incorporar evidencia al procedimiento penal.

Su artículo 51 reconoce la utilización de medios electrónicos durante el proceso penal, mientras que los artículos 227 y siguientes establecen las reglas relacionadas con la cadena de custodia.

Por tanto, los logs, imágenes forenses, dispositivos, archivos, registros de transacciones y demás evidencia digital deben ser obtenidos y preservados de forma que puedan ser presentados posteriormente ante la autoridad judicial.

---

9. Autoridades y dependencias que deberían intervenir

9.1 Banco de México

Banco de México es una autoridad central para este caso debido a su responsabilidad respecto del SPEI.

Durante los incidentes de 2018 implementó medidas de contención, operación contingente y controles adicionales para detectar operaciones anómalas.

Su participación resulta fundamental para:

- Analizar los eventos relacionados con SPEI.
- Coordinar medidas de contingencia.
- Establecer controles operativos.
- Intercambiar información con participantes.
- Fortalecer los mecanismos de seguridad del sistema.

9.2 Comisión Nacional Bancaria y de Valores

La CNBV tiene como objeto supervisar y regular, dentro de su ámbito de competencia, a las entidades integrantes del sistema financiero mexicano, buscando su estabilidad y correcto funcionamiento y la protección de los intereses del público.

Por ello, su intervención resulta relevante desde la perspectiva regulatoria y de supervisión de las instituciones financieras afectadas.

9.3 Fiscalía General de la República

La FGR podría intervenir cuando los hechos sean competencia federal.

La institución cuenta con capacidades especializadas para investigaciones relacionadas con medios electrónicos y tecnológicos. La entonces PGR creó la Unidad de Investigaciones Cibernéticas y Operaciones Tecnológicas, adscrita a la Agencia de Investigación Criminal, para apoyar investigaciones relacionadas con medios electrónicos y tecnológicos bajo conducción del Ministerio Público Federal.

Una investigación de este tipo requeriría:

- Peritos informáticos.
- Policía de investigación.
- Ministerio Público.
- Análisis financiero.
- Análisis de infraestructura.
- Cooperación con instituciones financieras.

9.4 Policía Cibernética

Las unidades de policía cibernética pueden colaborar en la identificación de infraestructura utilizada para cometer delitos, análisis de información tecnológica y prevención e investigación de incidentes.

Su participación dependería de la competencia específica de la unidad federal o estatal correspondiente.

9.5 CONDUSEF

La CONDUSEF podría intervenir principalmente desde la perspectiva de protección y orientación de usuarios de servicios financieros cuando existieran reclamaciones o afectaciones a usuarios.

No sustituye la investigación penal ni la supervisión especializada de la CNBV.

9.6 Fiscalías estatales

Dependiendo de la ubicación de los hechos y de la competencia jurídica correspondiente, también podrían participar fiscalías estatales, particularmente cuando existieran conductas delictivas cuya competencia correspondiera a una entidad federativa.

---

10. Reconstrucción técnico-forense del ataque

La siguiente reconstrucción representa un modelo de análisis basado en los hechos públicamente documentados:

Fase 1: Compromiso

El atacante obtiene acceso no autorizado a infraestructura tecnológica de un participante.

Fase 2: Control

El atacante consigue permisos suficientes para interactuar con componentes relevantes de la infraestructura.

Fase 3: Manipulación

Se modifica o altera algún componente del proceso utilizado para generar o transmitir órdenes de pago.

Fase 4: Inyección

Se introducen operaciones ilegítimas en el flujo transaccional.

Fase 5: Procesamiento

Las operaciones fraudulentas son procesadas hacia cuentas receptoras.

Fase 6: Disposición

Los recursos llegan a cuentas utilizadas para recibir y retirar el dinero.

Fase 7: Detección

La institución y las autoridades detectan anomalías en las operaciones.

Fase 8: Contención

Se implementan mecanismos de contingencia, alertas y controles adicionales.

Banco de México documentó precisamente que los atacantes insertaron transacciones ilegítimas en alguna etapa del proceso de los aplicativos de conexión, mientras que las medidas posteriores incluyeron plataformas de operación contingente y mecanismos adicionales de detección.

---

11. Prevención

El incidente demuestra que proteger únicamente el sistema central no es suficiente.

Una arquitectura financiera segura debe considerar también:

- Sistemas de terceros.
- Aplicaciones de conexión.
- Servidores.
- Redes internas.
- Credenciales.
- Administradores.
- Proveedores.
- Sistemas operativos.
- Bases de datos.
- Procesos de autorización.

11.1 Segmentación de red

Los sistemas relacionados con operaciones financieras deben encontrarse segmentados y aislados de redes de propósito general.

11.2 Principio de mínimo privilegio

Los usuarios y aplicaciones deberían contar únicamente con los permisos necesarios para desempeñar sus funciones.

11.3 Autenticación multifactor

Los accesos administrativos y críticos deberían requerir mecanismos adicionales de autenticación.

11.4 Monitoreo

Debe existir monitoreo continuo de:

- Autenticaciones.

- Procesos.
- Cambios de configuración.
- Tráfico.
- Aplicaciones.
- Transferencias.
- Comportamiento de usuarios.

11.5 Integridad de aplicaciones

Los ejecutables y componentes críticos deben contar con mecanismos que permitan detectar modificaciones no autorizadas.

11.6 Detección de anomalías financieras

El caso demuestra la importancia de combinar ciberseguridad con monitoreo financiero.

Un sistema debería ser capaz de detectar automáticamente:

- Transferencias fuera del comportamiento normal.
- Cuentas receptoras inusuales.
- Montos atípicos.
- Operaciones consecutivas.
- Patrones de dispersión.
- Cambios repentinos en el comportamiento de una cuenta.

---

12. Lecciones aprendidas

El ataque al SPEI demuestra que un sistema financiero puede mantener protegido su núcleo central y aun así sufrir una afectación importante si los sistemas periféricos o participantes presentan vulnerabilidades.

Una de las principales lecciones es que la seguridad debe considerarse como un **ecosistema**.

La dependencia de proveedores externos también representa un riesgo importante. Banco de México señaló que los aplicativos de conexión utilizados en los casos identificados habían sido desarrollados por terceros.

Por lo tanto, la seguridad de una institución financiera no depende exclusivamente de sus propios sistemas, sino también de:

- Proveedores.
- Software.
- Infraestructura.

- Personal.
- Procesos.
- Conexiones.
- Controles de terceros.

Otra lección importante es que la detección temprana puede reducir considerablemente el impacto económico.

Los mecanismos de monitoreo deben analizar simultáneamente eventos tecnológicos y financieros.

---

13. Conclusiones

El ataque contra participantes del SPEI ocurrido durante 2018 constituye un ejemplo significativo de ciberdelincuencia dirigida contra infraestructura financiera.

El caso demuestra que un atacante no necesita comprometer directamente el sistema central de pagos para provocar un impacto económico considerable. En este incidente, el objetivo fueron componentes de infraestructura y aplicaciones utilizadas por instituciones participantes.

La información publicada por Banco de México permite establecer que los atacantes vulneraron infraestructura tecnológica de participantes, manipularon procesos relacionados con aplicaciones de conexión e introdujeron transacciones ilegítimas. El SPEI central no fue vulnerado.

Desde la perspectiva de la informática forense, la investigación debería concentrarse en establecer una relación verificable entre el acceso inicial, los sistemas comprometidos, las modificaciones realizadas, las transacciones fraudulentas y las cuentas utilizadas para recibir y retirar los recursos.

Los principales elementos de evidencia serían logs, imágenes forenses, registros de autenticación, direcciones IP, archivos modificados, posibles muestras de malware, hashes, registros de aplicaciones y evidencia financiera.

Desde la perspectiva jurídica, los artículos 211 Bis y subsecuentes del Código Penal Federal resultan relevantes debido a las conductas relacionadas con el acceso y manipulación no autorizada de sistemas informáticos, incluyendo disposiciones específicas para instituciones del sistema financiero.

Asimismo, el Código Nacional de Procedimientos Penales resulta fundamental para garantizar que la evidencia digital pueda ser recolectada, preservada y presentada correctamente mediante mecanismos como la cadena de custodia.

Finalmente, el caso demuestra que la ciberseguridad financiera debe abordarse desde una perspectiva integral. No basta con proteger un sistema central: es necesario asegurar las

aplicaciones, proveedores, infraestructura, usuarios, redes y procesos que interactúan con él.

La prevención debe basarse en defensa en profundidad, mínimo privilegio, segmentación de redes, monitoreo continuo, análisis de anomalías, controles de integridad, autenticación robusta y coordinación permanente entre instituciones financieras y autoridades.

---

14. Referencias

Banco de México. (2018, mayo). *Información sobre los ataques a participantes del Sistema de Pagos Electrónicos Interbancarios (SPEI)*. Banco de México. Documento oficial de Banco de México

Banco de México. (2018). *Información importante sobre la situación del SPEI*. Banco de México. Información sobre ataques a participantes del SPEI

Cámara de Diputados del H. Congreso de la Unión. (2026). *Código Penal Federal*. Código Penal Federal

Cámara de Diputados del H. Congreso de la Unión. (2025). *Código Nacional de Procedimientos Penales*. Código Nacional de Procedimientos Penales

Cámara de Diputados del H. Congreso de la Unión. (2025). *Ley Federal de Protección de Datos Personales en Posesión de los Particulares*. Ley Federal de Protección de Datos Personales en Posesión de los Particulares

Comisión Nacional Bancaria y de Valores. (2023). *Objeto de la Comisión Nacional Bancaria y de Valores*. Gobierno de México. CNBV – Objeto

Fiscalía General de la República. (2017, 5 de septiembre). *La PGR crea las Unidades de Investigaciones Cibernéticas y Operaciones Tecnológicas*. Gobierno de México. Fiscalía General de la República